Procedimiento de Auditoría de Logs de Sistemas

Empresa: TechRetail
Versión: 1.0
Fecha: Septiembre 2025

---

1. Objetivo

Definir un proceso estandarizado para la **recolección, revisión, análisis y almacenamiento de logs de sistemas corporativos**, con el fin de garantizar la seguridad, trazabilidad y cumplimiento normativo en TechRetail.

---

2. Alcance

Este procedimiento aplica a:

- Servidores de aplicaciones, bases de datos y servicios críticos.
- Infraestructura de red (firewalls, switches, routers, VPN).
- Sistemas corporativos (ERP, CRM, HRM, POS).
- Plataformas cloud y contenedores (Azure, AWS, Docker, Kubernetes).

---

3. Principios de auditoría

- **Integridad:** los logs no deben ser alterados ni eliminados.
- **Centralización:** los registros deben consolidarse en un SIEM (ej. Splunk, ELK, Azure Sentinel).
- **Retención:** mínimo 12 meses de almacenamiento, de acuerdo con políticas internas.
- **Confidencialidad:** acceso restringido únicamente a personal autorizado.

---

4. Procedimiento

4.1 Recolección de logs

1. Configurar sistemas para enviar logs a la plataforma central (SIEM).
2. Categorías mínimas de registro:
    - **Acceso de usuarios** (inicio/cierre de sesión, intentos fallidos).
    - **Eventos de red** (firewall, VPN, IDS/IPS).
    - **Aplicaciones críticas** (ERP, CRM, POS, HRM).
    - **Cambios de configuración** en sistemas y bases de datos.

4.2 Revisión periódica

- **Diaria:** intentos de acceso fallidos, escalamiento de privilegios, errores críticos.
- **Semanal:** actividad de usuarios privilegiados, cambios en políticas de seguridad.
- **Mensual:** patrones de anomalías, correlación de eventos, cumplimiento normativo.

4.3 Análisis e investigación

1. Usar el SIEM para generar alertas en tiempo real.
2. Clasificar incidentes en niveles: **informativo, advertencia, crítico**.
3. Escalar eventos sospechosos al equipo de Seguridad TI.
4. Documentar hallazgos en el sistema de tickets corporativo.

4.4 Retención y archivo

- Logs recientes (0–90 días): almacenamiento en línea en SIEM.
- Logs históricos (91–365 días): archivo en almacenamiento seguro y cifrado.
- Eliminación automática después de 12 meses, salvo requerimientos legales.

---

5. Buenas prácticas

- Implementar **alertas automáticas** para accesos fuera de horario laboral.
- Revisar logs de bases de datos para detectar **consultas masivas o sospechosas**.
- Proteger los archivos de log con **hashes (SHA-256)** para verificar su integridad.
- Realizar auditorías cruzadas entre diferentes sistemas para correlación de eventos.

---

6. Escenario práctico (ejemplo)

- **Evento detectado:** 50 intentos fallidos de acceso a HRM desde una misma IP.
- **Acción:** alerta automática en SIEM.
- **Investigación:** correlación muestra intentos en VPN y correo.
- **Resultado:** bloqueo de IP, restablecimiento de credenciales del usuario afectado, informe al Comité de Seguridad.

---

7. Roles y responsabilidades

- **Infraestructura TI:** configuración de logging en servidores y dispositivos.
- **Seguridad TI:** monitoreo, análisis y respuesta a incidentes.
- **Auditoría Interna:** revisión mensual de cumplimiento y reportes.
- **Comité de Seguridad:** aprobación de medidas correctivas.

---

8. Indicadores clave (KPIs)

- % de logs enviados al SIEM sin pérdida.
- Tiempo promedio de detección de incidentes.
- Número de accesos no autorizados detectados.
- Casos cerrados dentro de SLA definidos.

---

9. Contacto de soporte

📧 seguridad-ti@techretail.com
☎️ Ext. 1500 – Equipo de Seguridad y Monitoreo
🕒 Monitoreo 24/7